

Integrations와 Security

팀 도구 연동과 다층 보안 방어

One agent for everywhere you code - CLI, IDE, App, Web

Codex Deep Dive Workshop (2-Day) - Module 8 / Integrations and Security

Choi, WooHyung

Prin. Solutions Architect

AWS Korea

whchoi@amazon.com



MODULE 08

Integrations와 Security

팀 도구 연동과 다층 보안 방어



이 모듈의 목표

이 모듈에서 얻어갈 네 가지

GOAL

이 모듈을 마치면 Codex를 팀 도구에 연동하고, 위협 모델을 이해하며, 프롬프트 인젝션을 방어하고, 보수적 기본값으로 안전하게 도입할 수 있습니다.

INTEGRATE

도구 연동

GitHub, Slack, Linear에 에이전트를 통합합니다

THREAT

위협 이해

코딩 에이전트의 위협 모델을 파악합니다

DEFEND

인젝션 방어

외부 콘텐츠를 데이터로 취급해 방어합니다

ADOPT

안전 도입

보수적 기본값과 최소 권한으로 운영합니다

60 min

강의 45 + 랩 15

3

팀 도구 연동

5

주요 위협 유형

Lab 7

이슈에서 PR까지

Integrations 개요

팀 도구와 연결

GITHUB

GitHub

이슈, PR, 코드 리뷰 워크플로우에 통합합니다

SLACK

Slack

채팅에서 작업을 지시하고 결과를 받습니다

LINEAR

Linear

이슈 트래킹과 작업 흐름에 연결합니다

WORKFLOW FIT 통합의 목적은 Codex를 기존 도구 흐름 안으로 가져오는 것입니다.
도구를 떠나지 않고 에이전트를 활용할 수 있습니다.

PRINCIPLE

원칙: 새 도구를 익히는 대신, 이미 쓰는 도구 안에서 에이전트를 부른다

GitHub

이슈, PR 흐름

Slack

채팅 호출

Linear

이슈 트래킹

Fit

기존 흐름 유지

GitHub Integration

이슈에서 PR까지

1 Issue

이슈에 작업 지시

2 Assign

Codex에 할당

3 Work

에이전트 작업

4 PR

PR 생성

5 Review

사람 리뷰, 머지

WORKFLOW

GitHub 워크플로우

- 이슈에 멘션이나 코멘트로 작업을 요청
- Codex가 브랜치를 만들고 변경을 구현한 뒤 PR을 자동 생성하고 작업 내용을 설명
- 리뷰 코멘트에 반응해 추가 수정을 수행, 머지는 사람이 결정

ISSUE-DRIVEN 이슈가 작업 단위가 됩니다. 명확한 재현 절차가 담긴 이슈일수록 에이전트의 결과 품질이 높아집니다.

@mention

이슈에서 요청

Branch

자동 브랜치

PR

자동 생성, 설명

Comment

리뷰 반응 수정

GitHub 연동 설정

설정 단계와 보안 권장

SETUP

설정 단계

- GitHub App 설치 또는 OAuth 연결
- 대상 리포지토리에 접근 권한 부여
- 동작할 브랜치와 정책 구성
- 필요한 시크릿과 토큰을 안전하게 설정

SECURITY

보안 권장

- 최소 권한 원칙으로 접근 범위 제한
- 보호 브랜치와 리뷰 필수 규칙 유지
- 에이전트 변경도 동일한 CI 게이트 통과
- 감사 로그로 활동 추적

SAME GATE 에이전트의 변경도 사람의 변경과 똑같이 보호 브랜치, 리뷰 필수, CI 게이트를 통과해야 합니다. 에이전트라고 예외를 두지 마십시오.

App/OAuth

연결 방식

Least-priv

최소 권한

Protected

보호 브랜치

CI gate

동일 게이트

Slack Integration

채팅에서 에이전트 호출

SLACK

Slack에서 Codex를 멘션해 작업을 지시하고, 진행 상황과 결과를 채널에서 바로 확인합니다. 팀 협업과 자연스럽게 결합됩니다.

MENTION

멘션 호출

채널이나 DM에서 멘션으로 작업을 시작합니다

CONTEXT

맥락 공유

스레드 대화를 작업 맥락으로 활용합니다

NOTIFY

결과 알림

완료와 PR 링크를 채널에 알립니다

COLLAB

협업

팀이 함께 진행 상황을 지켜봅니다

@mention

채널, DM 호출

Thread

스레드 맥락

Notify

PR 링크 알림

Team

함께 지켜봄

Linear Integration

이슈 트래킹과 연결

FEATURES

주요 기능

- Linear 이슈를 Codex 작업으로 변환
- 이슈 상태와 작업 진행을 동기화
- 완료 시 결과와 PR을 이슈에 연결
- 스프린트 작업을 에이전트로 가속

BENEFITS

기대 효과

- 기획과 실행 사이의 간극을 축소
- 반복적이고 명확한 이슈를 자동 처리
- 사람은 복잡한 이슈에 집중
- 진행 상황이 트래커에 투명하게 반영

PLAN TO EXEC Linear 통합의 가치는 기획과 실행의 연결입니다.
명확한 이슈는 에이전트가 처리하고, 사람은 판단이 필요한 복잡한 이슈에 집중합니다.

Convert

이슈를 작업으로

Sync

상태 동기화

Link

PR 이슈 연결

Focus

사람은 복잡 이슈

Codex Security Overview

보안 개요

SECURITY MODEL

코딩 에이전트는 코드 실행 권한을 갖기에 보안이 핵심입니다. Codex는 샌드박싱, 권한, 검토, 감사의 다층 방어를 제공합니다.

ISOLATION

격리

샌드박스로 실행을 시스템과 분리합니다

PERMISSION

권한

최소 권한과 승인으로 동작을 통제합니다

REVIEW

검토

자동과 사람 리뷰로 위험한 변경을 차단합니다

AUDIT

감사

활동 로그로 사후 추적을 보장합니다

Sandbox

실행 격리

Least-priv

권한 통제

Review

변경 차단

Audit

사후 추적

위협 모델

주요 위협과 대응

01	프롬프트 인젝션	외부 콘텐츠를 데이터로 취급, 경계 적용	최우선
02	민감 데이터 유출	네트워크 차단, 시크릿 격리	유출
03	악의적 코드 실행	샌드박스 격리, 승인 게이트	실행
04	권한 오남용	최소 권한, 범위 제한	권한
05	공급망 위험	신뢰된 MCP, 플러그인만 사용	공급망

ASSUME BREACH 외부에서 들어온 모든 콘텐츠는 잠재적으로 적대적일 수 있다고 가정하고, 명령이 아니라 데이터로 처리하는 것이 기본 원칙입니다.

Injection

최우선 위협

Leak

네트워크 차단

Sandbox

실행 격리

Supply

출처 검증

프롬프트 인젝션 방어

외부 콘텐츠를 데이터로

1 외부 콘텐츠

웹, 파일, 이슈

2 데이터 취급

명령 아님

3 경계 적용

신뢰 분리

4 승인

민감 동작

WHY IT MATTERS

왜 중요한가

- 에이전트가 읽는 외부 텍스트에 악성 지시가 숨을 수 있음
- 예: 이슈 본문에 모든 시크릿을 외부로 보내라는 문구가 섞여 있는 경우
- 이런 지시는 절대 명령으로 실행하지 않고 데이터로 처리, 민감하거나 비가역적 동작은 항상 사람 승인

CONCRETE 이슈, PR 코멘트, 웹 페이지, 파일 내용은 모두 외부 입력입니다.

담긴 지시는 사용자의 명령이 아니라 검토 대상 데이터일 뿐입니다.

External

웹, 파일, 이슈

As data

명령 아닌 데이터

Boundary

신뢰 경계

Approve

민감 동작 승인

Security Setup

안전한 도입 설정

INITIAL

초기 설정

- 기본 승인 정책을 보수적으로 설정
- 네트워크는 기본 차단, 필요 시 허용 목록
- 시크릿은 환경 변수로만 주입
- 보호 브랜치와 CI 게이트 유지

OPERATIONS

운영 정책

- 팀 표준 config로 정책 일관성 확보
- MCP, 플러그인 출처 검증 프로세스
- 정기적인 권한과 접근 검토
- 활동 로그 수집과 모니터링

CONSERVATIVE DEFAULT 안전 도입의 핵심은 보수적 기본값입니다.
처음에는 엄격하게 시작해 신뢰가 쌓이면 점진적으로 완화하는 것이, 그 반대보다 훨씬 안전합니다.

Conservative

보수적 기본값

Default-off

네트워크 차단

Standard

팀 config 일관성

Monitor

로그 모니터링

Module 8 요약과 Security FAQ

핵심 정리와 자주 묻는 질문

SUMMARY

GitHub, Slack, Linear로 기존 도구 흐름에 에이전트를 넣고, 격리와 권한, 검토, 감사의 다층 방어와 인젝션 경계로 안전하게 운영합니다.

Q1	코드가 학습에 쓰이나요?	데이터 정책에 따름, 엔터프라이즈는 제어 가능	데이터
Q2	로컬 코드가 유출되나요?	샌드박스과 네트워크 정책으로 통제	유출
Q3	임의 명령을 실행하나요?	승인 정책과 샌드박스로 제한	실행
Q4	감사가 가능한가요?	활동 로그로 추적 가능	감사

NEXT 다음 Module 9에서는 SDK와 GitHub Action으로 이 통합과 보안 원칙을 코드와 CI에 옮깁니다.

Integrate

도구 연동

Defense

다층 방어

Least-priv

최소 권한

Lab 7

이슈 위임 실습

Mini Lab 7 (15분)

GitHub 이슈를 Codex에 맡기기

MISSION

리포에 Codex GitHub 연동을 설치하고, 작은 이슈를 작성해 멘션으로 위임한 뒤, PR을 받아 리뷰 코멘트로 추가 수정까지 확인합니다.

01	연동	리포에 Codex GitHub 연동(App) 설치	Step 1
02	이슈	재현 절차가 명확한 작은 이슈 1개 작성	Step 2
03	할당	이슈에서 Codex를 멘션해 작업 요청	Step 3
04	리뷰	생성된 PR에 리뷰 코멘트, 추가 수정 확인	Step 4

보안 체크 / CHECKPOINT 이슈 본문에 외부 텍스트를 붙일 때는 인젝션 가능성을 항상 의심하고 권한은 최소로 유지하십시오.
작업 시작, PR 요약 포함, 리뷰 반응, CI 통과 후 머지를 확인하면 통과입니다.

15 min

제한 시간

Issue to PR

전체 흐름

최소 권한

보안 원칙 적용

CI 게이트

통과 후 머지

Thank you!

Choi, WooHyung / Prin. Solutions Architect / AWS Korea

whchoi@amazon.com

<https://linkedin.com/in/woohyungchoi>

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

